OpenClaw

사용자 보안 가이드

— 비기술자를 위한 핵심 요약—

"보안 위험 종합 보고서" 기반 요약본

작성일: 2026년 4월 10일

기준 버전: OpenClaw v2026.4.7-1

1. OpenClaw이 뭐예요?

OpenClaw은 AI가 컴퓨터를 직접 조작하는 프로그램입니다. 텔레그램이나 디스코드 같은 메신저로 명령을 내리면, AI가 알아서 파일을 읽고, 메시지를 보내고, 프로그램을 실행하는 자동화 도구입니다.

문제는 이것입니다: OpenClaw은 기본 설정 그대로 사용하면, 여러분의 컴퓨터에서 거의 모든 것을 할 수 있는 권한을 가집니다. 비밀번호, 개인 파일, API 키 같은 민감한 정보에도 접근할 수 있습니다.

⚠️ 글로벌 보안 기관들의 경고
Microsoft: “개인/기업 작업용 PC에 설치하기에 적합하지 않다”
Kaspersky: “사용에 안전하지 않다(unsafe for use)”
Cisco: “개인 AI 에이전트는 보안의 악몽” — 위험 분석 및 Skill Scanner 공개
중국 정부: 정부기관·국영은행에서 사용 제한 (Bloomberg, 2026.3)

2. 주요 위험 한눈에 보기

아래는 OpenClaw 사용 시 실제로 발생한/발생할 수 있는 위험입니다.

위험 유형	무슨 일이 생길 수 있나요?	심각도
비밀번호/키 노출	AI가 에러 로그에 비밀번호나 API 키를 평문으로 기록. 실제로 4만개 이상 인스턴스에서 발견됨	함부로 명령하면 안 됨
악성 플러그인	편리해 보이는 확장 기능(Skill)이 알고 보면 해킹 도구. 공식 마켓의 12~20%가 악성으로 발견됨	검증 없이 설치 금지
웹 해킹(ClawJacked)	악성 웹사이트 방문만으로 AI가 해커에게 넘어감. 패치 완료되었으나 설정 변경 시 재발 가능	최신 버전 유지 필수
대규모 데이터 유출	API 토큰 150만개 + 사용자 이메일 35,000개가 실제로 유출된 사례. “AI 역사상 최대 보안 사고”로 평가	실제 발생 사고
무단 파일 접근	설정 실수로 AI가 여러분 홈 폴더·SSH 키·지갑 등에 접근 가능	권한 제한 필수
프롬프트 조작	외부에서 AI에게 몰래 명령을 주입. 예: 메시지에 숨겨진 명령으로 파일 삭제/전송	균형 잡힌 구성 필요

3. 반드시 지켜야 할 규칙

하지 마세요 ❌

1. 업무용 PC나 개인 메인 컴퓨터에 직접 설치하지 마세요
→ 해킹당하면 PC 전체가 위험해집니다. 별도 컴퓨터를 사용하세요.
2. 검증 없이 Skill(확장 기능)을 설치하지 마세요
→ 공식 마켓(ClawHub)의 12~20%가 악성입니다. 반드시 코드를 확인한 사람이 검증한 것만 사용하세요.
3. 인증 기능을 끄거나 무시하지 마세요
→ 인증 없이 공개된 인스턴스가 수만 개 발견되었습니다. OpenClaw은 게이트웨이 토큰을 자동 생성해주므로, 이 기능을 활성화한 채로 유지하세요.
4. 업데이트 없이 방치하지 마세요
→ 63일 동안 138개 이상의 보안 결함이 발견되었습니다. 업데이트 알림이 오면 바로 적용하세요.
5. AI에게 무제한 권한을 주지 마세요
→ AI가 접근할 수 있는 폴더와 명령을 최소한으로 제한하세요. “모두 허용”은 절대 선택하지 마세요.

반드시 하세요 ✅

1. 별도 컴퓨터(VM 또는 리눅스 서버)에서 사용하세요
→ 문제가 생겨도 메인 컴퓨터에 피해가 없습니다.
2. 항상 최신 버전을 유지하세요 (v2026.4.7-1 이상)
→ 업데이트마다 중요한 보안 패치가 포함됩니다.
3. 게이트웨이 인증이 활성화되어 있는지 확인하세요
→ OpenClaw은 게이트웨이 토큰을 자동으로 생성합니다. 이 기능이 켜져 있는지 확인하고, 인증 없이 접속되지 않도록 유지하세요.
4. AI의 중요한 행동에는 “사람 승인”을 활성화하세요
→ 파일 삭제, 메시지 발송, 프로그램 실행 전에 반드시 사람이 확인하는 설정(Exec Approvals)을 켜두세요.
5. 관리자/IT팀에게 보안 설정을 요청하세요
→ 보안 설정은 복잡합니다. 혼자 하기 어려우면 반드시 전문가에게 도움을 받으세요.

4. 어디에 설치해야 안전한가요?

아래 표에서 녹색에 가까울수록 안전합니다.

설치 위치	안전도	설명
별도 리눅스 서버 + Docker	★★★★★	가장 추천. 별도 컴퓨터 + 격리 환경으로 이중 보호
별도 리눅스 서버 (직접 설치)	★★★★	별도 컴퓨터라 좋지만 보안 설정을 직접 해야 함
메인 컴퓨터(Mac/Win) + Docker	★★★	Docker가 어느 정도 보호하지만, 문제 시 메인 PC에 영향
Windows WSL2	★★	격리처럼 보이지만 실제로는 Windows와 맞붙어 있음
메인 컴퓨터에 직접 설치	★	**절대 비추천.** 해킹 시 모든 개인정보·작업 파일이 위험

핵심 메시지: "별도 컴퓨터에 설치하고, 메인 PC와 분리하세요." 이것 하나만 기억하셔도 대부분의 위험을 피할 수 있습니다.

5. 실제로 발생한 사고들

이론이 아니라 실제로 일어난 사건들입니다:

사고	무슨 일이 있었나요?
대규모 데이터 유출	API 토큰 150만개와 사용자 이메일 35,000개가 한 번에 유출되었습니다. 서버 설정 오류 하나가 원인이었습니다.
Mac 악성코드	편리해 보이는 Skill을 설치했더니, Mac의 비밀번호·인증서·SSH 키·문서를 통째로 탈취하는 악성코드였습니다.
보안 없는 인스턴스	42,665개 인스턴스 중 93.4%가 비밀번호 없이 누구나 접근 가능한 상태로 발견되었습니다.
봇 토큰 노출	텔레그램 봇의 비밀 토큰이 에러 로그에 평문으로 기록되어 유출되었습니다.

6. 보안 체크리스트

아래 항목을 확인하고, 해당하지 않는 항목이 있으면 IT 담당자에게 문의하세요.

항목	상태	비고
별도 컴퓨터/서버에 설치되어 있나요?	□ 예 / □ 아니오	**가장 중요**
최신 버전(v2026.4.7-1+)을 사용 중인가요?	□ 예 / □ 아니오	
게이트웨이 인증(토큰)이 활성화되어 있나요?	□ 예 / □ 아니오	
사람 승인 기능(Exec Approvals)이 켜져 있나요?	□ 예 / □ 아니오	
Skill(확장 기능)을 검증 후 설치했나요?	□ 예 / □ 아니오	
AI 접근 폴더/권한이 최소한으로 제한되어 있나요?	□ 예 / □ 아니오	
정기 업데이트 일정이 있나요?	□ 예 / □ 아니오	

한 줄 요약
OpenClaw은 강력하지만 위험한 도구입니다. 반드시 별도 컴퓨터에서 격리하여 사용하고, 인증 기능을 활성화하고, 항상 최신 버전을 유지하세요. 잘 모르겠으면 IT 담당자에게 물어보세요.

본 문서는 *"OpenClaw 보안 위험 및 사용자 주의사항 종합 보고서(2026.4.10)"*를 기반으로 비기술자용으로 요약한 문서입니다. 세부 내용은 종합 보고서를 참조하세요.